

LU2 Verbeteronderzoek Security Beroepsproduct v1.0

Module: ATlx IN-B2.4 Softwarearchitectuur & -kwaliteit 2025-26 P4

Criteria	Onvoldoende	Voldoende	Goed	Criterion Score
Security audit (wetgeving & normen)	0 points De resultaten van de audit t.a.v. NEN7510 ontbreken of zijn onduidelijk en niet bruikbaar vastgelegd. Er is geen onderbouwd advies opgenomen.	11 points De gap naar volledige implementatie van relevante NEN7510-2 controls is vastgelegd. Er is een advies opgenomen voor verbetering van de compliancy op basis van een lijst non-compliances die is geprioriteerd op basis van risico-inschatting.	20 points Bevat alle onderdelen van "Voldoende" en de audit is grondig, herleidbaar en onderbouwd met relevante bronnen en normen. De prioritering en aanpak zijn expliciet gemotiveerd.	/ 20
Secure pipelines	0 points De pipelines zijn niet secure ingericht of de verschillende OTAP-omgevingen zijn onvoldoende gescheiden. Documentatie is onvoldoende.	8 points De pipelines zijn secure ingericht inclusief scheidingen naar de OTAP-omgevingen. Documentatie verantwoordt de gemaakte keuzes en geeft inzicht in de toegepaste veiligheidsmaatregelen.	15 points Bevat alle onderdelen van "Voldoende" en er is verantwoorde keuze gemaakt voor niet-herleidbare data in de verschillende OTAP-omgevingen.	/ 15

Criteria	Onvoldoende	Voldoende	Goed	Criterion Score
Advies up-dates (SBOM, CVE en CVSS)	0 points De analyse van afhankelijkheden ontbreekt of is onvolledig en niet bruikbaar vastgelegd. Er is geen of een onvoldoende onderbouwd advies over updates van libraries op basis van CVE's en CVSS-scores.	8 points Er is een duidelijke en (machine)bruikbare SBOM gegenereerd die de relevante afhankelijkheden van het systeem beschrijft. Er is een bruikbaar en onderbouwd advies opgesteld over updates van afhankelijkheden op basis van SBOM, CVE's en CVSS-scores.	15 points Bevat alle onderdelen van "Voldoende" en het advies bevat een duidelijke prioritering, afweging van impact en risico's en concrete aanbevelingen voor implementatie.	/ 15
Security code review & kwetsbaarheden	0 points Security code reviews ontbreken of zijn onvoldoende uitgevoerd. Kwetsbaarheden zijn niet duidelijk vastgelegd of onderbouwd.	9 points Security code reviews zijn uitgevoerd met (AI-)tooling. Kwetsbaarheden zijn duidelijk en bruikbaar vastgelegd, onderbouwd en geprioriteerd. Risico's bij niet oplossen zijn beschreven op basis van valide bronnen.	15 points Bevat alle onderdelen van "Voldoende" en de analyse is diepgaand, met goed onderbouwde risico-inschattingen en duidelijke relatie tussen kwetsbaarheden en systeemgebruik.	/ 15

Criteria	Onvoldoende	Voldoende	Goed	Criterion Score
Penetration tests (aantonen kwetsbaarheden)	0 points Penetration tests ontbreken of zijn niet navolgbaar gedocumenteerd. Misbruik van kwetsbaarheden is niet aantoonbaar gemaakt.	8 points Penetration tests zijn uitgevoerd en navolgbaar gedocumenteerd, waarbij misbruik van de meest kritische kwetsbaarheden is aangetoond.	15 points Bevat alle onderdelen van “Voldoende” en de tests zijn systematisch opgezet, reproduceerbaar en geven diepgaand inzicht in exploitatie en impact.	/ 15
Mitigatie & validatie verbeteringen	0 points Kwetsbaarheden zijn niet gemitigeerd of de mitigaties zijn niet aantoonbaar effectief. Verantwoording van realisatie ontbreekt.	11 points Kwetsbaarheden zijn gemitigeerd en met penetration tests is aangetoond dat securityrisico’s zijn verlaagd. De realisatie is verantwoord, inclusief gebruik van (AI)tooling.	20 points Bevat alle onderdelen van “Voldoende” en de verbetering is kwantitatief en reproduceerbaar aangetoond. Er is een kritische reflectie op de gekozen mitigaties en tooling.	/ 20

Total	/ 100
-------	-------

Overall Score

Onvoldoende
0 points minimum

Voldoende
55 points minimum

Goed
100 points minimum